

PraisonAI's unauthenticated A2A official example can reach real LLM-driven `eval()` tool execution

Report Type: Weekly · Generated: May 31, 2026 05:30 UTC · Coverage: May 29 – May 31, 2026

1	1	0	0
Total Advisories	Critical	High	Medium

Executive Summary

Summary The first-party PraisonAI A2A server example combines three behaviors into a remotely exploitable Critical chain: 1. The example exposes an A2A server without configuring `auth\_token`. 2. The same example binds the server to `0.0.0.0`. 3. The example registers a `calculate(expression)` tool implemented with Python `eval(expression)`. An unauthenticated network client can send a JSON-RPC `message/send` request to `/a2a`. The A2A handler passes the attacker-controlled message to `agent.chat()`. With a real Gemini LLM (`gemini/gemini-2.5-flash-lite`), the model invoked the registered `calculate` tool, causing the example's `eval()` call to execute Python in the server process. The canary wrote a marker file from an unauthenticated `/a2a` request. This is not a claim that every A2A deployment is automatically RCE. The Critical chain is confirmed for the first-party A2A example, and for deployments that follow the same pattern: public unauthenticated A2A plus an unsafe tool s

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
PraisonAI's unauthenticated A2A official example can reach real LLM-driven eval tool	CRITICAL	9.8	—	## Summary The first-party PraisonAI A2A server example combines three

MITRE ATT&CK;® Coverage

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Advisory Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for PraisonAI's unauthenticated A2A official example can reach real LLM-driven `eval()` tool execution.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK; techniques.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--b99b8bbdfe18
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T05:30:23.536190+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.